

Estudio 1:
Análisis de Tráfico y Escaneo de Puertos

Estudiante
Oscar Arturo Chavarría

Ciberseguridad, CENFOTEC
Introducción a la Ciberseguridad

Profesor
Brandon Álvarez

Febrero 2025

Índice

Portada	1
Índice	2
Desarrollo	3
Zenmap	3
Ejercicio 1: Conexión y Prueba de Red desde VM	3
Ejercicio 2: Escaneo rápido de Puertos	4
Ejercicio 3: Escaneo Plus de puertos	6
Ejercicio 4: Escaneo de vulnerabilidades	7
Wireshark	9
Paso 1: Captura de tráfico HTTP	9
Paso 2: Análisis de tráfico HTTP	11
Paso 3: Captura de tráfico HTTPS	12
Paso 4: Análisis de tráfico HTTPS	14
Reflexión final	15

Desarrollo

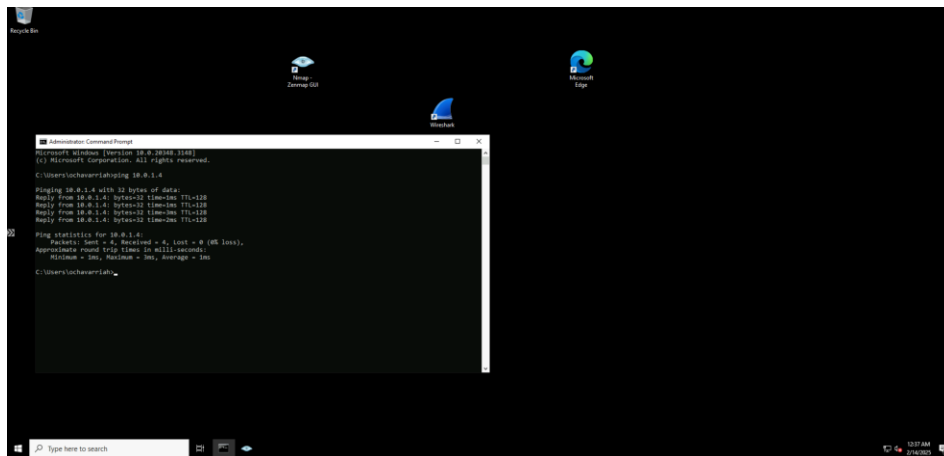
Zenmap

Ejercicio 1: Conexión y Prueba de Red desde VM

- Ingresar a sus VMs utilizando Bastion. El usuario es el nombre de usuario de su correo institucional y la clave es **Cenfotec2025**.
- Realicen un ping a alguna IP de sus compañeros dentro de la misma subnet.
- Tomen un screenshot que muestre los resultados del ping incluyendo su VM como “Source” y la VM del compañero como “Destination”.

Entregable:

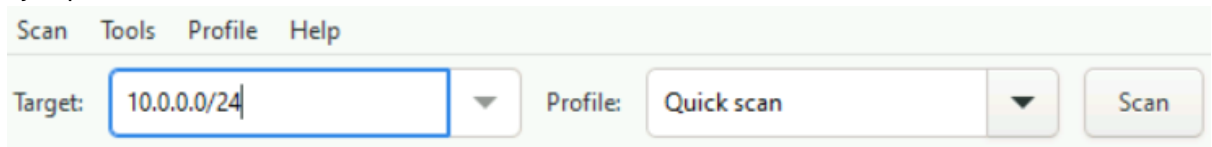
- Screenshot mostrando los resultados del ping a uno de sus compañeros (1pt)



Ejercicio 2: Escaneo rápido de Puertos

- Ejecute Zenmap y realice un escaneo de puertos en su subnet asignada.

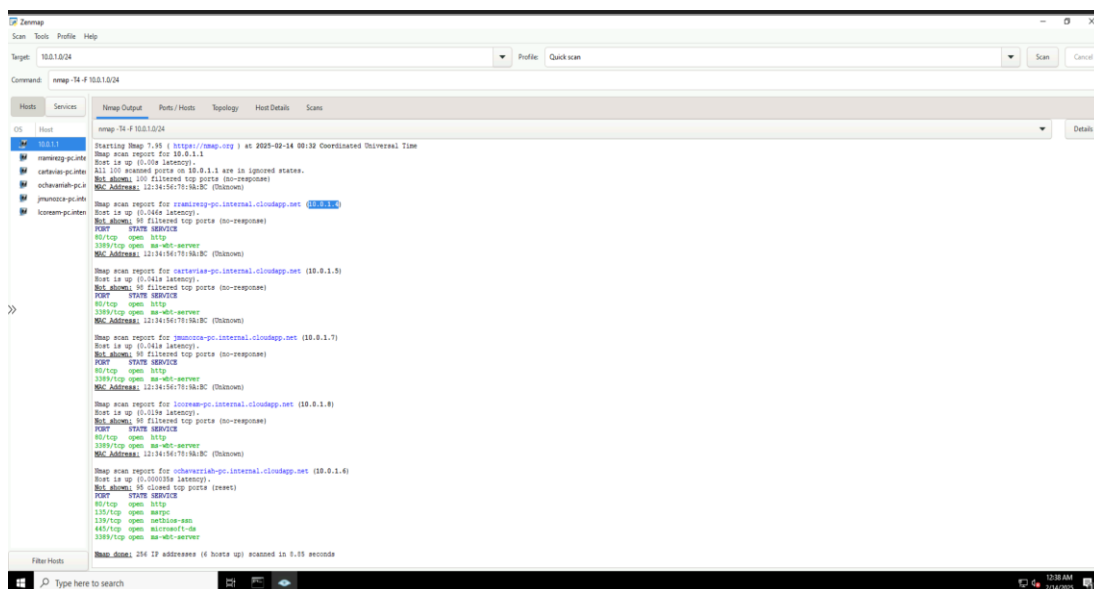
1. Target => su subnet
2. Profile => quickscan
3. Ejemplo:



- Tomen un screenshot mostrando el resultado del escaneo.
- Tomen nota de cuales puertos están abiertos

Entregables:

- Screenshot del resultado del escaneo (1pt).



- Pregunta, ¿Cuántos hosts hay en su subnet y cuáles son sus IPs? (1pt)

Hay 6 Hosts si contamos el host 10.0.1.1 en el subnet 10.0.1.0/24 más los hosts

rramirezg: 10.0.1.4

cartavias: 10.0.1.5

jmunozca: 10.0.1.7

lcoream: 10.0.1.8

ochavarriah: 10.0.1.6

- Pregunta, ¿Cuáles puertos están abiertos? (1pt)

rramirezg: 2 puertos abiertos

cartavias: 2 puertos abiertos

jmunozca: 2 puertos abiertos

lcoream: 2 puertos abiertos

ochavarriah: 4 puertos abiertos

- Pregunta, ¿Cuáles servicios están habilitados? (1pt)

rramirezg: http y ms-wbt-server

cartavias: http y ms-wbt-server

jmunozca: http y ms-wbt-server

lcoream: http y ms-wbt-server

ochavarriah: http, msrpc, netbios-ssn, microsoft-ds y ms-wbt-server

Ejercicio 3: Escaneo Plus de puertos

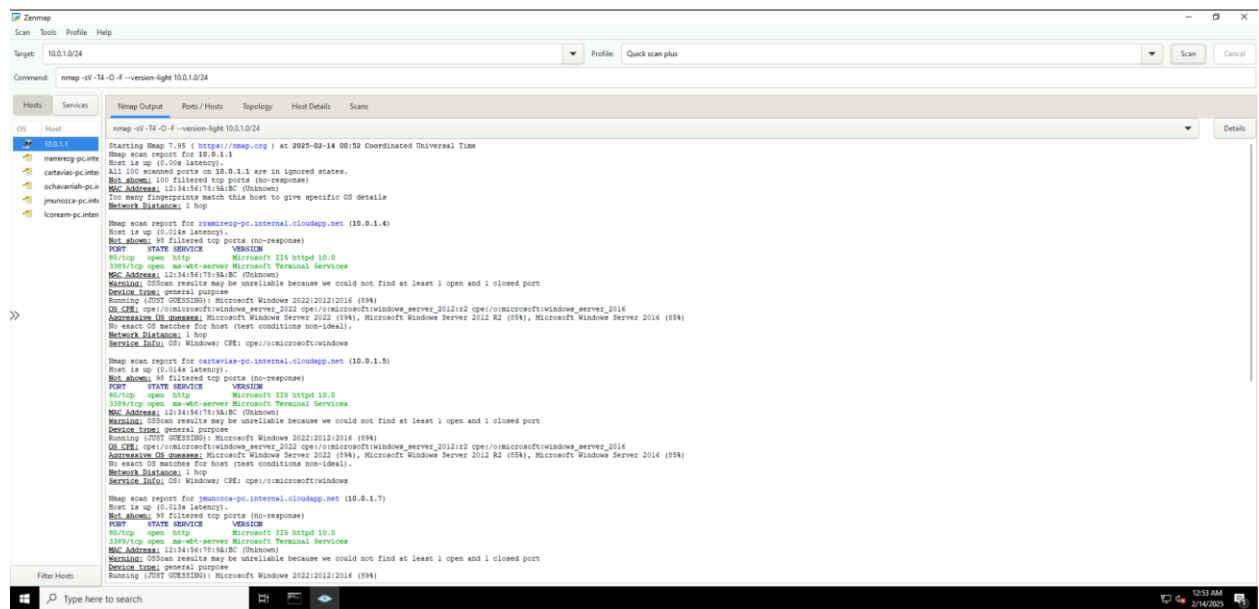
- Ejecute Zenmap y realice un escaneo de puertos en su subnet asignada.
 1. Target => su subnet
 2. Profile => quickscan plus
 3. Ejemplo:

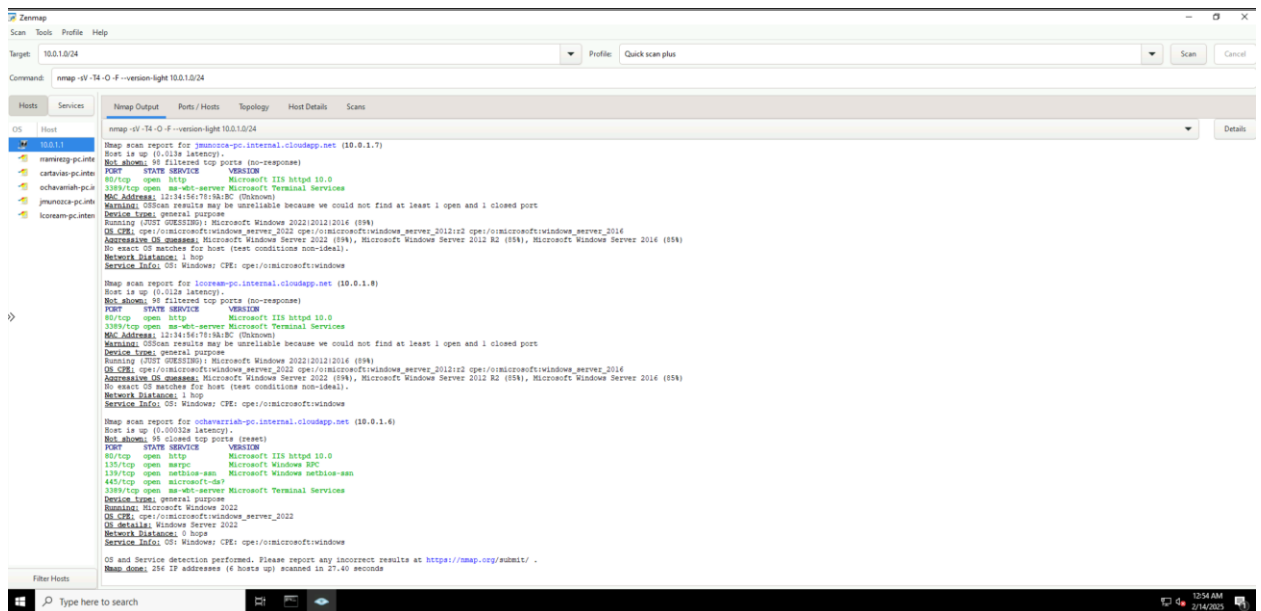
Target: 10.0.0.0/24 Profile: Quick scan plus Scan

- Espere al menos unos 30 segundos a que termine el escaneo.

Entregables:

- Screenshot del resultado del escaneo (1pt).





- Pregunta, ¿Cuál es el sistema operativo de las máquinas en su subnet? (1pt)

El sistema operativo de las maquinas es Windows

Ejercicio 4: Escaneo de vulnerabilidades

- Ejecute Zenmap y realice un escaneo de puertos en su subnet asignada.
 1. Target => su subnet
 2. Command => `nmap --script vuln < su subnet >`
 3. Ejemplo:

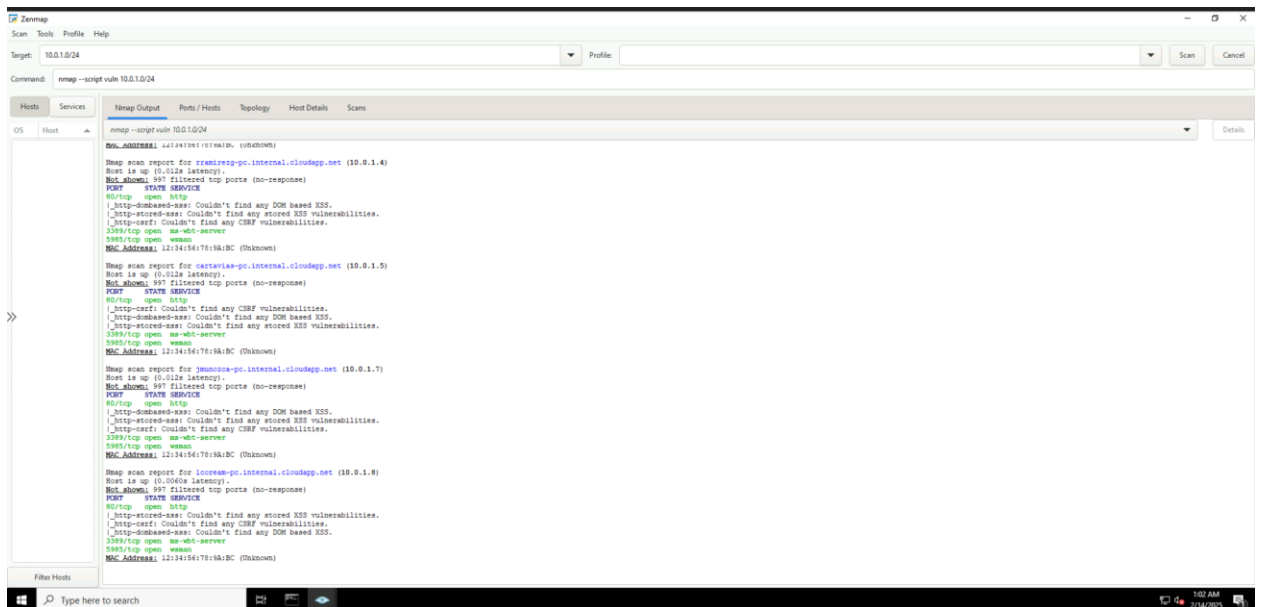
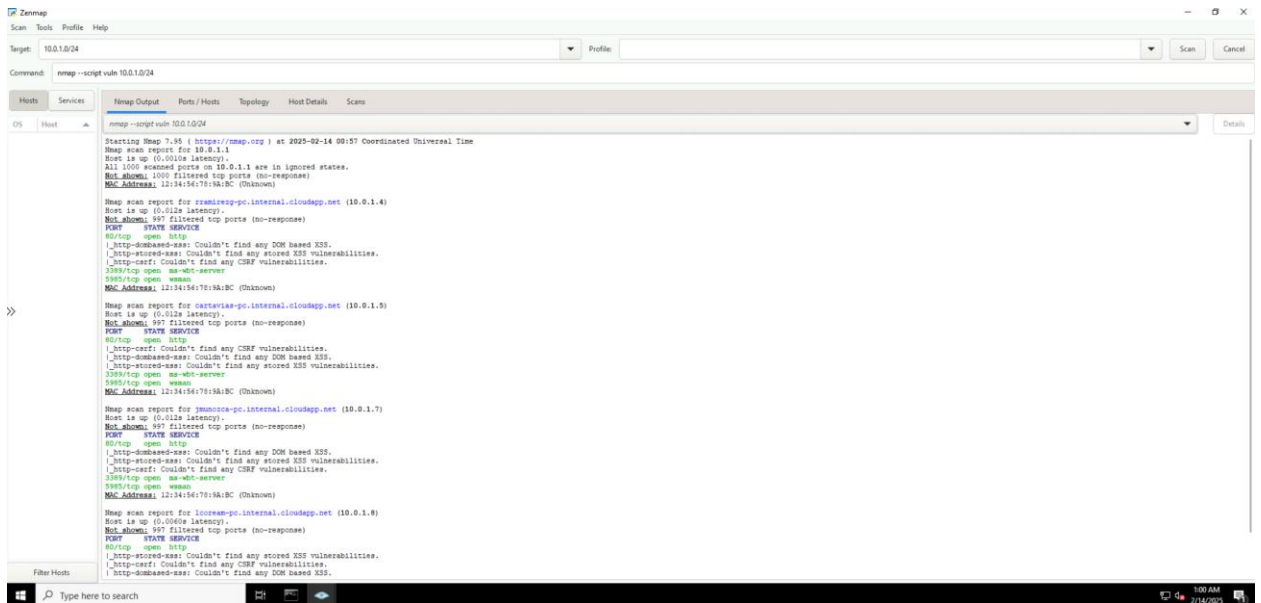
Target: Profile:

Command:

- Espere unos minutos a que termine el escaneo.

Entregables:

- Screenshot del resultado del escaneo (1pt).



- Pregunta, ¿Cuáles vulnerabilidades se intentó encontrar? (1pt)

Intento encontrar vulnerabilidades XSS, CSRF y DOM based XSS en el puerto 80

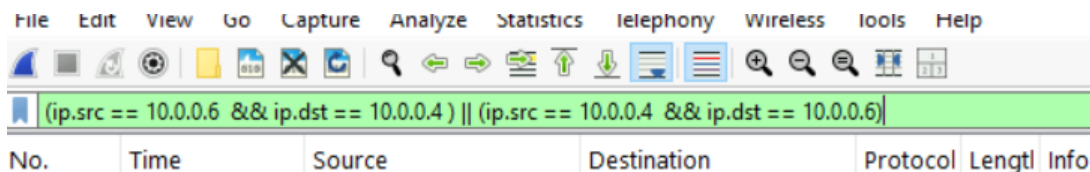
Wireshark

Paso 1: Captura de tráfico HTTP

- Ingrese en Azure (<https://portal.azure.com/>)
- Diríjase a “laboratorio-rg” e ingrese a su máquina virtual (username-vm).
- Conéctese a la máquina virtual utilizando Bastion, utilice su username y la clave Cenfotec2025
- Una vez que haya entrado a la máquina virtual busque y ejecute Wireshark.



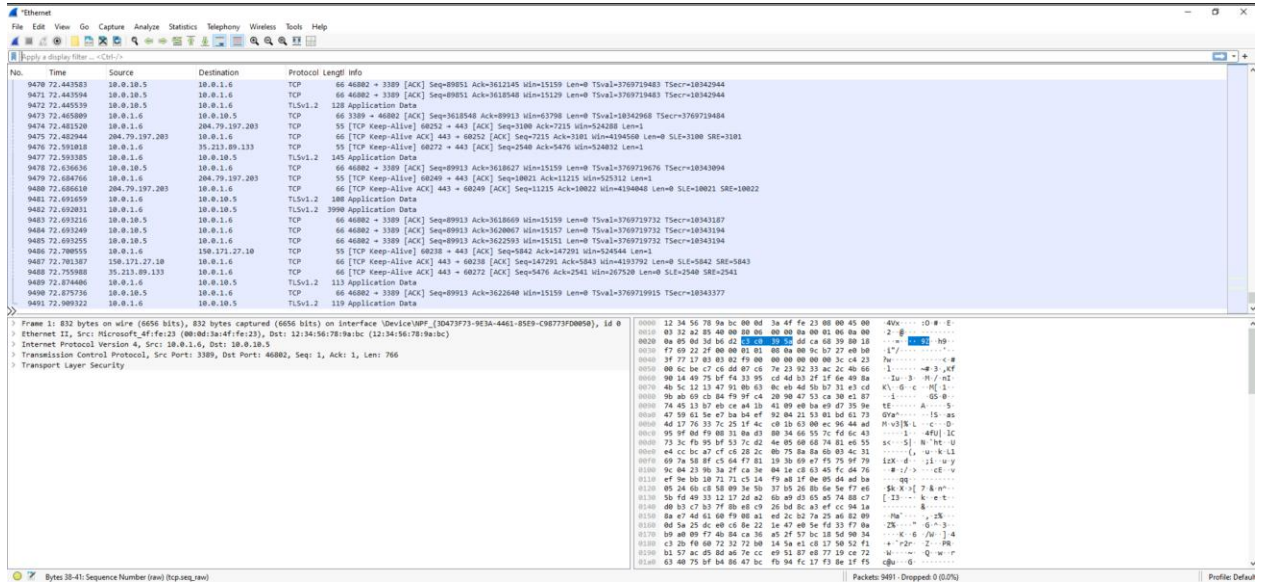
- Inicie una captura de tráfico seleccionando **Capture -> Start**
- Acceda a la aplicación **LoginApp** en <http://login> desde el navegador Microsoft Edge dentro de su máquina virtual y realice un intento de inicio de sesión utilizando su usuario y la clave **Cenfotec2025**
- Regrese al Wireshark y detenga la captura de tráfico seleccionando **Capture -> Stop**
- Realice una captura de pantalla del tráfico capturado.
- Aplique un filtro para solo ver el tráfico entre su IP y la IP del servidor web.
 - Siga este formato:
`(ip.src == <ip_servidor_web> && ip.dst == <ip_estudiante> ) || (ip.src == <ip_estudiante> && ip.dst == <ip_servidor_web> )`
 - Por ejemplo, si la IP del servidor web es 10.0.0.4 y la IP del estudiante es 10.0.0.6, entonces el filtro sería:
`(ip.src == 10.0.0.6 && ip.dst == 10.0.0.4 ) || (ip.src == 10.0.0.4 && ip.dst == 10.0.0.6)`



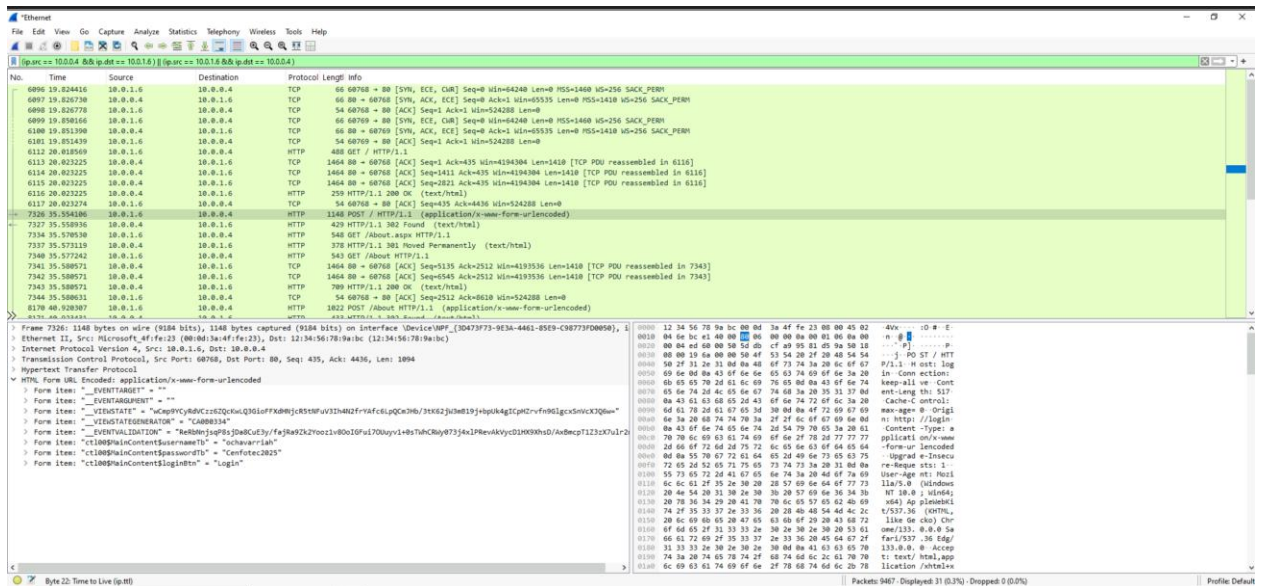
No olvide aplicar el filtro presionando “Enter” o este botón:

Entregable:

- Captura de pantalla de Wireshark mostrando tráfico HTTP capturado (1pt).



- Captura de pantalla de Wireshark con el filtro aplicado, mostrando solo el tráfico entre su IP y la IP del servidor web (1pt).



Paso 2: Análisis de tráfico HTTP

- Examine los paquetes capturados en Wireshark y busque el paquete donde se enviaron sus credenciales.
 - Pista:** Busque un paquete de tipo POST /Default HTTP/1.1 (application/x-www-form-urlencoded).
- Encuentre las credenciales transmitidas en texto plano sin cifrar.
 - El paquete luce similar a este:

```
> Hypertext Transfer Protocol
✓ HTML Form URL Encoded: application/x-www-form-urlencoded
  > Form item: "__EVENTTARGET" = ""
  > Form item: "__EVENTARGUMENT" = ""
  > Form item: "__VIEWSTATE" = "WC6/sAVSLzPHPAuh2cyhCzJ/yw2QT0GFqL+
  > Form item: "__VIEWSTATEGENERATOR" = "CA0B0334"
  > Form item: "__EVENTVALIDATION" = "APPiwTELaBTUQgzDST/lBhhK1jvM%
  > Form item: "ctl00$MainContent$usernameTb" = "balvarezg"
  > Form item: "ctl00$MainContent$passwordTb" = "Cenfotec2025"
  > Form item: "ctl00$MainContent$loginBtn" = "Login"
```

Entregable:

- Captura de pantalla de Wireshark mostrando las credenciales capturadas en texto plano (1pt).

```
> Frame 7326: 1148 bytes on wire (9184 bits), 1148 bytes captured (9184 bits) on interface \Device\NPF_{3D473F73-9E3A-4461-85E9-C98773FD0050}, i
> Ethernet II, Src: Microsoft_4f:fe:23 (00:0d:3a:4f:fe:23), Dst: 12:34:56:78:9a:bc (12:34:56:78:9a:bc)
> Internet Protocol Version 4, Src: 10.0.1.6, Dst: 10.0.0.4
> Transmission Control Protocol, Src Port: 60768, Dst Port: 80, Seq: 435, Ack: 4436, Len: 1094
> Hypertext Transfer Protocol
✓ HTML Form URL Encoded: application/x-www-form-urlencoded
  > Form item: "__EVENTTARGET" = ""
  > Form item: "__EVENTARGUMENT" = ""
  > Form item: "__VIEWSTATE" = "wCmp9YCYRdVCzz6ZQcKwLQ3GioFFXdhNjcR5tNFuV3Ih4N2frYAfc6LpQCmJHb/3tK62jW3mB19j+bpUk4gICpHZrvfn9GlgcxSnVcXJQ6w="
  > Form item: "__VIEWSTATEGENERATOR" = "CA0B0334"
  > Form item: "__EVENTVALIDATION" = "ReRbNnjsqP8sjDa8CuE3y/fajRa9Zk2Yooz1v8OoIGFui70Uuyv1+0sTwhCRWY073j4x1PRevAkVycD1HX9XhsD/Ax8mcpT1Z3zX7u1r2
  > Form item: "ctl00$MainContent$usernameTb" = "ochavarriah"
  > Form item: "ctl00$MainContent$passwordTb" = "Cenfotec2025"
  > Form item: "ctl00$MainContent$loginBtn" = "Login"
```

- Pregunta: ¿Por qué la información de las credenciales está en texto plano y es fácilmente legible? (1pt).

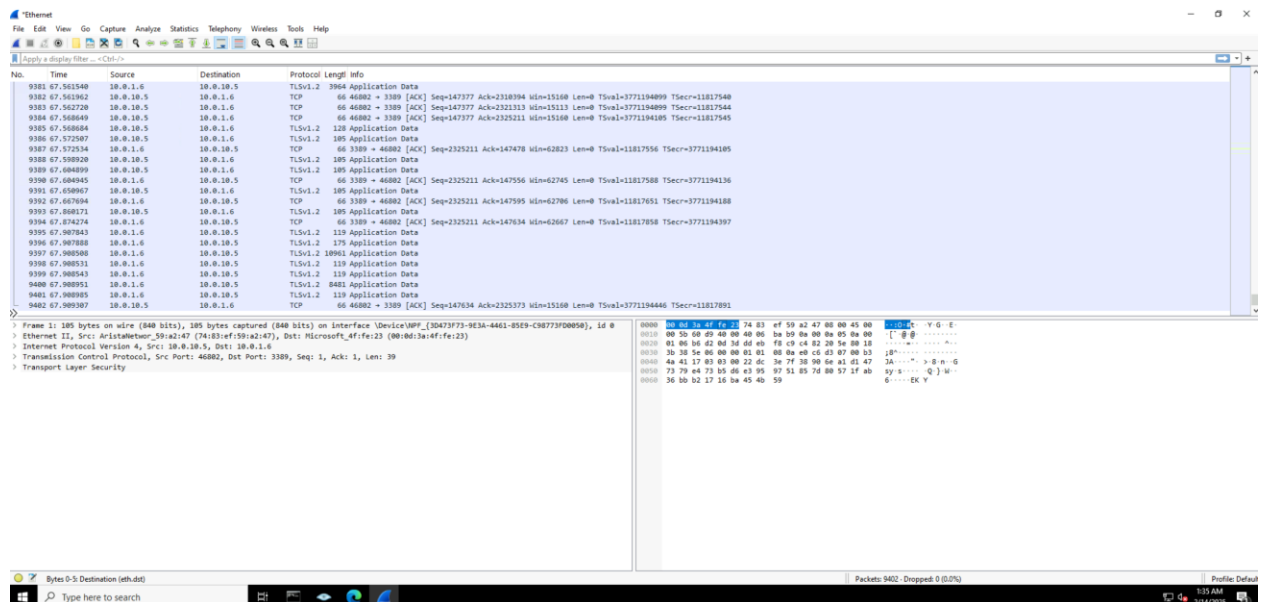
Es fácilmente legible ya que entramos a una página no segura o no cifrada "http"

Paso 3: Captura de tráfico HTTPS

- Cierre el navegador Microsoft Edge
- En Wireshark, inicie una nueva captura de tráfico seleccionando **Capture -> Start**
 - Click en "Continue without saving"
- Abra Microsoft Edge e ingrese al **LoginApp** en <https://loginseguro>
- Intente ingresar con su usuario y la clave **Cenfotec2025**
- Regrese al Wireshark y detenga la captura de tráfico seleccionando **Capture -> Stop**
- Realice una captura de pantalla del tráfico capturado.
- Aplique el mismo filtro del Paso 1

Entregable:

- Captura de pantalla de Wireshark mostrando tráfico HTTPS capturado (1pt).



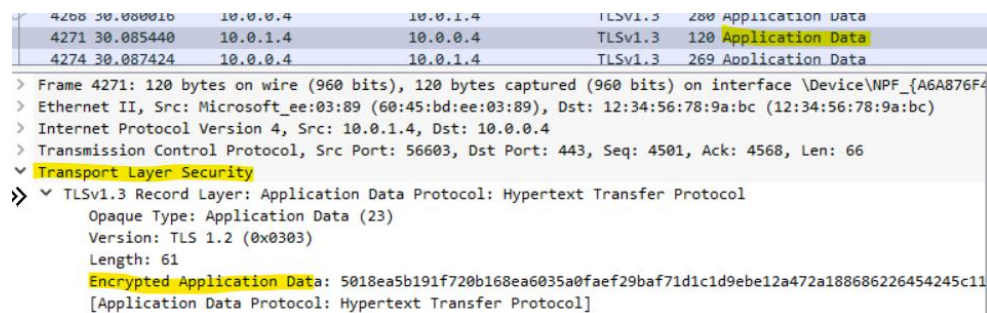
- Captura de pantalla de Wireshark con el filtro aplicado, mostrando solo el tráfico entre su IP y la IP del servidor web (1pt).

[illegible]

Paso 4: Análisis de tráfico HTTPS

Búsqueda de Datos Cifrados (Application Data):

- Al utilizar https, el tráfico HTTP es reemplazado por datos cifrados, mostrados en Wireshark como **Application Data**. Estos paquetes contienen la información intercambiada entre el cliente y el servidor, en este caso, las credenciales ingresadas en **LoginApp**, pero ahora en formato cifrado.
- Observe cómo no se pueden ver las credenciales en texto claro, a diferencia del tráfico HTTP capturado previamente.



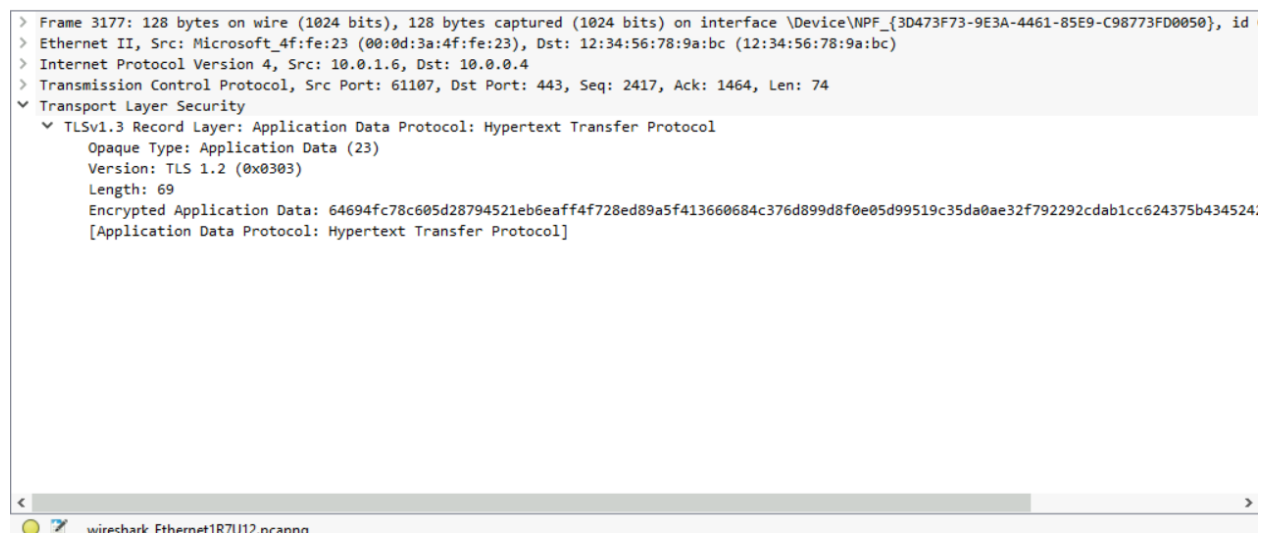
The image shows a Wireshark packet capture. The top table lists three packets: 4268, 4271, and 4274. Packet 4271 is selected, showing details for Ethernet II, Internet Protocol Version 4, and Transmission Control Protocol. The expanded 'Transport Layer Security' section shows 'TLSv1.3 Record Layer: Application Data Protocol: Hypertext Transfer Protocol'. The 'Encrypted Application Data' field contains a long hexadecimal string.

```
4268 30.080016 10.0.0.4 10.0.1.4 TLSv1.3 280 Application Data
4271 30.085440 10.0.1.4 10.0.0.4 TLSv1.3 120 Application Data
4274 30.087424 10.0.0.4 10.0.1.4 TLSv1.3 269 Application Data

> Frame 4271: 120 bytes on wire (960 bits), 120 bytes captured (960 bits) on interface \Device\NPF_{A6A876F4...}
> Ethernet II, Src: Microsoft_ee:03:89 (60:45:bd:ee:03:89), Dst: 12:34:56:78:9a:bc (12:34:56:78:9a:bc)
> Internet Protocol Version 4, Src: 10.0.1.4, Dst: 10.0.0.4
> Transmission Control Protocol, Src Port: 56603, Dst Port: 443, Seq: 4501, Ack: 4568, Len: 66
▼ Transport Layer Security
  >> TLSv1.3 Record Layer: Application Data Protocol: Hypertext Transfer Protocol
    Opaque Type: Application Data (23)
    Version: TLS 1.2 (0x0303)
    Length: 61
    Encrypted Application Data: 5018ea5b191f720b168ea6035a0faef29baf71d1c1d9ebe12a472a188686226454245c11
    [Application Data Protocol: Hypertext Transfer Protocol]
```

Entregable:

- Captura de pantalla de Wireshark mostrando el contenido de alguno de los paquetes "Application Data" (1pt)



The image shows a Wireshark packet capture. The top table lists three packets: 3177, 3178, and 3179. Packet 3177 is selected, showing details for Ethernet II, Internet Protocol Version 4, and Transmission Control Protocol. The expanded 'Transport Layer Security' section shows 'TLSv1.3 Record Layer: Application Data Protocol: Hypertext Transfer Protocol'. The 'Encrypted Application Data' field contains a long hexadecimal string.

```
> Frame 3177: 128 bytes on wire (1024 bits), 128 bytes captured (1024 bits) on interface \Device\NPF_{3D473F73-9E3A-4461-85E9-C98773FD0050}, id
> Ethernet II, Src: Microsoft_4f:fe:23 (00:0d:3a:4f:fe:23), Dst: 12:34:56:78:9a:bc (12:34:56:78:9a:bc)
> Internet Protocol Version 4, Src: 10.0.1.6, Dst: 10.0.0.4
> Transmission Control Protocol, Src Port: 61107, Dst Port: 443, Seq: 2417, Ack: 1464, Len: 74
▼ Transport Layer Security
  >> TLSv1.3 Record Layer: Application Data Protocol: Hypertext Transfer Protocol
    Opaque Type: Application Data (23)
    Version: TLS 1.2 (0x0303)
    Length: 69
    Encrypted Application Data: 64694fc78c605d28794521eb6eaff4f728ed89a5f413660684c376d899d8f0e05d99519c35da0ae32f792292cdab1cc624375b434524
    [Application Data Protocol: Hypertext Transfer Protocol]
```

- Pregunta: ¿Por qué esta vez no se pueden ver las credenciales en texto plano? (1pt)

Porque este es un sitio web de acceso seguro donde la información es encriptada.

Reflexión final

Reflexione y responda las siguientes preguntas.

1. ¿Por qué es importante realizar escaneos de puertos y vulnerabilidades en una red empresarial y qué riesgos pueden surgir si no se implementan adecuadamente? (2pts)

Es importante ya que con ello podemos identificar vulnerabilidades y también evaluar los riesgos que puedan tener los sistemas.

2. ¿Cuál es la importancia de utilizar HTTPS en la transmisión de credenciales en comparación con HTTP? (2pts)

La importancia de utilizar https para la transmisión de credenciales reside en el cifrado que utiliza https para proteger la información transmitida en un sitio web.